



UNIVERSIDAD TECNOLÓGICA DE PANAMÁ

Facultad de Ingeniería de Sistemas Computacionales · Licenciatura en Desarrollo de Software

ISO/IEC 27001:2022 en el Sector Público

Evaluación de riesgos, controles operativos y política de mantenimiento de sistemas — Caso ANSDP

INTEGRANTES

Figueroa, Josue (8-936-934)

Jaen, Alexis (8-985-332)

Moreno, Alexander (8-1005-116)

Page, Jonathan (8-976-1568)

Ye, Jimmy (4-817-2479)

Materia: Seguridad en los Sistemas de Información
Docente: Prof. Lizmayrem Marquez
Fecha: Miércoles, 01 de julio de 2026

Agenda de la presentación



01

Introducción y contexto institucional



02

Alcance del SGSI y partes interesadas



03

Estructura organizacional y arquitectura tecnológica



04

Inventario de activos y matriz RACI



05

Metodología y matriz de evaluación de riesgos



06

Controles de seguridad del Grupo No. 5



07

Checklist y política de mantenimiento de sistemas



08

Conclusiones y referencias

¿Qué es la ANSDP?

La Autoridad Nacional de Servicios Digitales Públicos (ANSDP) es una institución pública ficticia encargada de administrar trámites digitales ciudadanos: emisión de certificados, gestión de solicitudes, expedientes digitales y atención en línea.

Al procesar información personal y documentación sensible, requiere un Sistema de Gestión de Seguridad de la Información (SGSI) que proteja la confidencialidad, integridad y disponibilidad de sus activos.

El proyecto aplica la metodología de ISO/IEC 27005 e ISO 31000 para la evaluación de riesgos, y controles de ISO/IEC 27001 e ISO/IEC 27002, con foco en seguridad de las operaciones y mantenimiento de sistemas.

CIA

Confidencialidad · Integridad · Disponibilidad

ISO 27005

Metodología de gestión de riesgos

ISO 31000

Marco general de gestión de riesgos

Contexto de la organización



Contexto interno

Grandes volúmenes de datos personales (nombres, cédulas, direcciones, expedientes).
Sistemas web, servidores, bases de datos, red institucional, personal técnico y administrativo, y procesos de atención ciudadana.



Contexto externo

Exposición a ciberataques, malware, suplantación de identidad, accesos no autorizados y fuga de información. Debe cumplir la Ley 81 de 2019 y el Decreto Ejecutivo 285 de 2021 sobre protección de datos personales en Panamá.



Partes interesadas

Ciudadanos, funcionarios internos, dirección general, departamento de tecnología, unidad de seguridad, proveedores tecnológicos, entidades fiscalizadoras y autoridades de protección de datos.

Alcance del SGSI

El SGSI se aplica a todos los procesos tecnológicos y administrativos de la gestión de trámites digitales ciudadanos de la ANSDP, protegiendo la confidencialidad, integridad y disponibilidad de la información bajo su custodia.



Incluye

- Sistemas web de atención ciudadana
- Bases de datos con información personal
- Servidores institucionales
- Personal de tecnología y personal administrativo con acceso a datos ciudadanos
- Procesos de respaldo, acceso, almacenamiento y recuperación de información

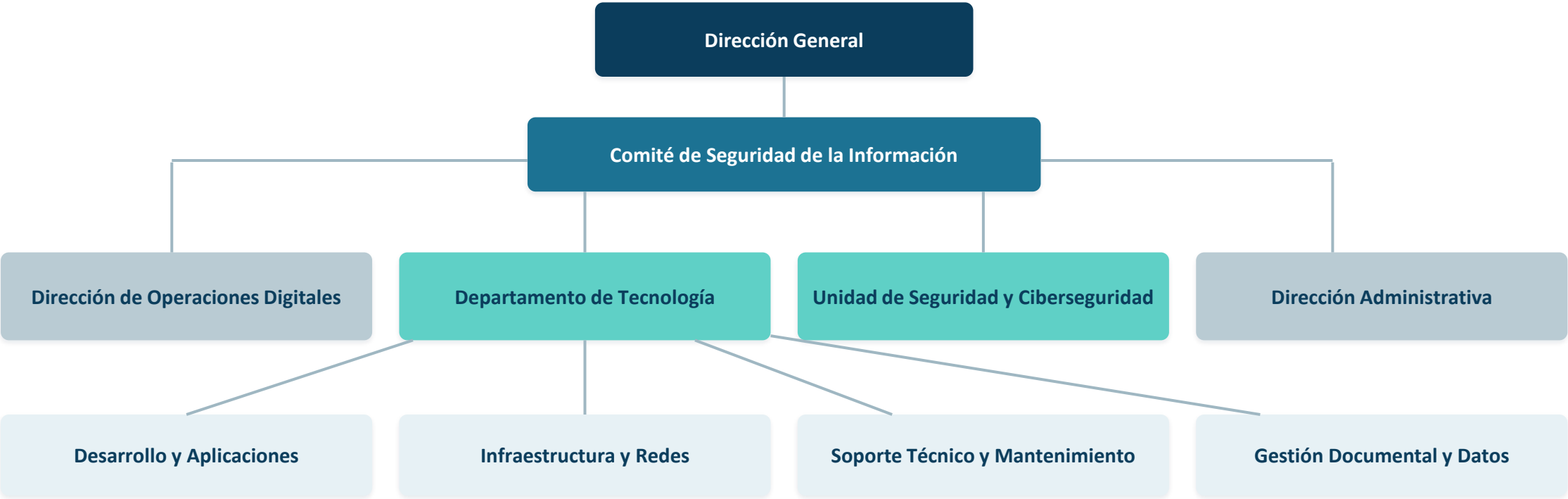


No incluye

Procesos manuales externos que no estén conectados con los sistemas digitales de la institución.

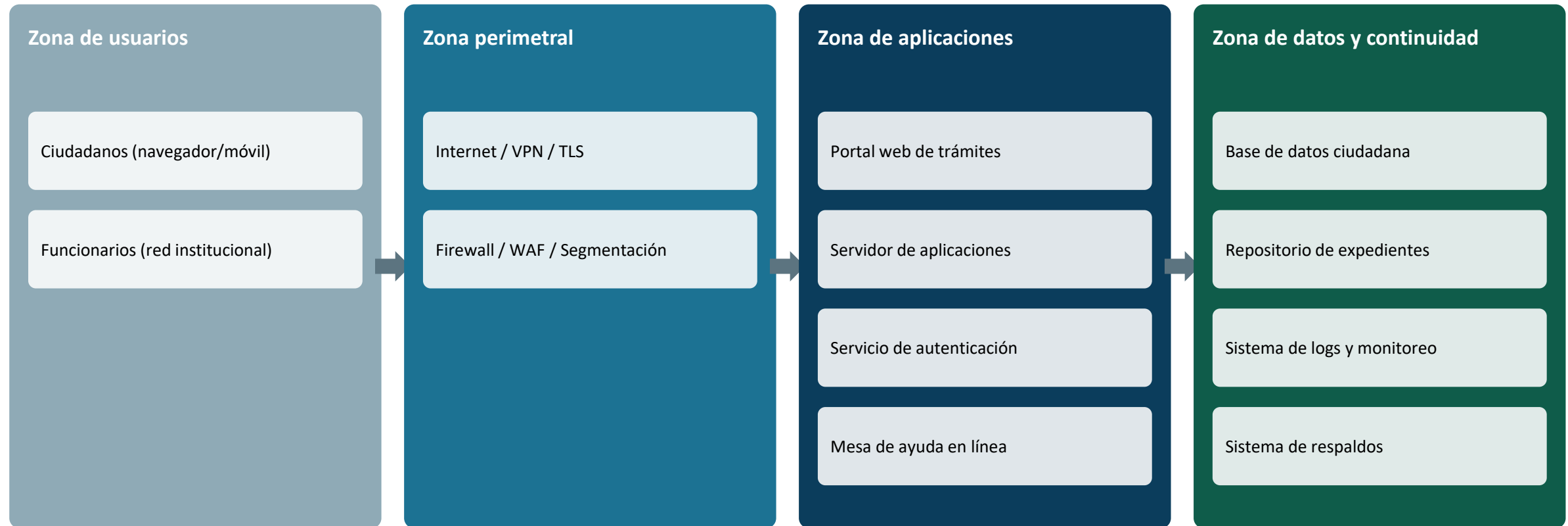
Estructura organizacional

La seguridad de la información se ubica como una función transversal. La Dirección General mantiene la responsabilidad final del SGSI; el Comité de Seguridad coordina decisiones sobre riesgos, políticas y continuidad; el Departamento de Tecnología y la Unidad de Seguridad ejecutan las medidas técnicas.



Arquitectura tecnológica propuesta

Separación en zonas de usuarios, perimetral, aplicaciones y datos — permite aplicar controles de segmentación, monitoreo, respaldos, autenticación y mantenimiento controlado.



Inventario de activos tecnológicos

Activo	Tipo	Criticidad	Justificación
Portal web de trámites	Software/servicio	Alta	Canal principal de atención pública.
Base de datos ciudadana	Información/software	Crítica	Contiene información personal y datos sensibles.
Servidor de aplicaciones	Hardware/software	Alta	Su falla afecta la continuidad del servicio.
Servidor de autenticación	Servicio	Crítica	Controla el acceso a expedientes y sistemas.
Repositorio de expedientes digitales	Información	Crítica	Documentos personales y evidencias oficiales.
Sistema de respaldos	Servicio	Crítica	Permite recuperación ante fallas o ransomware.
Firewall / WAF	Hardware/software	Alta	Reduce exposición a ataques externos.
Sistema de logs y monitoreo	Software/servicio	Alta	Facilita detección e investigación de incidentes.
Estaciones de trabajo administrativas	Hardware	Media	Punto inicial de malware o phishing.
Servicio de atención en línea	Software/servicio	Media	Afecta percepción ciudadana y continuidad.

Departamento técnico y matriz RACI

Organización en áreas de infraestructura, desarrollo, soporte, base de datos y seguridad, coordinadas mediante una matriz RACI para evitar duplicidad de responsabilidades.

Actividad	Dir. Gral.	Jefe TI	Of. Seguridad	Infraest.	DBA	Desarrollo	Soporte
Aprobar política de mantenimiento	A	R	C	C	C	C	I
Planificar mantenimientos programados	I	A/R	C	R	R	C	C
Aplicar parches del sistema operativo	I	A	C	R	C	I	C
Mantener base de datos y respaldos	I	A	C	C	R	I	I
Revisar logs y alertas operativas	I	A	R	C	C	I	C
Registrar evidencias de mantenimiento	I	A	C	R	R	R	R
Autorizar cambios en producción	I	A	C	R	C	R	I
Comunicar ventana de mantenimiento	I	A	C	R	C	C	R

R = Responsable de ejecutar · A = Aprobador · C = Consultado · I = Informado

Metodología de evaluación de riesgos

Enfoque basado en activos, alineado con ISO/IEC 27005 (gestión de riesgos de seguridad de la información) e ISO 31000 (guía general de gestión de riesgos).



Matriz de riesgos — resumen prioritario

Activo crítico	Amenaza principal	Riesgo inherente	Control propuesto	Riesgo residual
Portal web de trámites	Explotación de vulnerabilidades web	Crítico	Actualización, monitoreo, revisión de logs y pruebas antes de producción.	Medio
Base de datos ciudadana	Acceso no autorizado o fuga de datos	Crítico	Cifrado, respaldos, auditoría y revisión de privilegios.	Bajo
Servidor de aplicaciones	Malware o explotación remota	Alto/Crítico	Hardening, parches y mantenimiento programado.	Medio
Sistema de respaldos	Falla de restauración ante ransomware	Alto/Crítico	Regla 3-2-1, copia offline y pruebas de restauración.	Bajo
Sistema de logs y monitoreo	No detección de actividad anómala	Alto	Centralización de logs, alertas y retención mínima.	Medio

La matriz de riesgos completa se entrega en archivo Excel adjunto.

Controles de seguridad del Grupo No. 5

Enfocados en seguridad de las operaciones y mantenimiento de sistemas, seleccionados de ISO/IEC 27001 e ISO/IEC 27002.



Gestión de vulnerabilidades técnicas

Escaneo mensual de servidores, portal y estaciones administrativas.



Gestión de configuración

Baseline para servidores, firewall, bases de datos y aplicaciones.



Copias de seguridad

Backups diarios y prueba trimestral de restauración.



Registro de eventos

Logs de acceso, cambios, errores y autenticación.



Monitoreo de actividades

Alertas por caídas, accesos fallidos y uso anormal.



Instalación controlada de software

Restricción de instalación en servidores y estaciones.



Gestión de cambios

Cambios con aprobación, pruebas y plan de reversa.



Mantenimiento de equipos y sistemas

Mantenimiento preventivo, correctivo, adaptativo y evolutivo.

Checklist de mantenimiento preventivo

#	Verificación	Frecuencia	Responsable
1	Servidores institucionales operativos	Diaria	Administrador de Sistemas
2	Funcionamiento del portal ciudadano	Diaria	Administrador de Aplicaciones
3	Ejecución correcta de respaldos	Diaria	Administrador de Sistemas
4	Registros de errores, accesos fallidos o eventos sospechosos	Diaria	Analista de Seguridad
5	Disponibilidad e integridad de la base de datos ciudadana	Semanal	Administrador de Base de Datos
6	Actualizaciones o parches pendientes	Semanal	Administrador de Sistemas
7	Prueba de restauración de información crítica	Mensual	Adm. de Sistemas / DBA
8	Cuentas de usuarios, permisos y accesos administrativos	Mensual	Seguridad de la Información

Checklist de mantenimiento correctivo / urgencia

#	Verificación	Momento	Responsable
1	Registro de la falla o incidente en la mesa de ayuda	Al detectar	Mesa de Ayuda
2	Identificación del activo afectado	Inmediato	Administrador de Sistemas
3	Clasificación del nivel de impacto	Inmediato	Analista de Seguridad
4	Revisión de logs para determinar la causa	Durante atención	Analista de Seguridad / TI
5	Acción de contención aplicada	Durante atención	Seguridad de la Información / TI
6	Verificación de respaldos recientes	Antes de restaurar	Adm. de Sistemas / DBA
7	Validación de funcionamiento tras la corrección	Post-intervención	Adm. de Aplicaciones / QA
8	Documentación de causa raíz y acciones correctivas	Cierre del caso	Responsable asignado

Política de mantenimiento de sistemas



Objetivo

Establecer principios, responsabilidades y procedimientos para el mantenimiento preventivo, correctivo, adaptativo y evolutivo de los sistemas de la ANSDP.



Alcance

Servidores, bases de datos, aplicaciones web, estaciones administrativas, red institucional, firewall, autenticación, respaldos, expedientes y atención en línea del SGSI.

Principios

- ✓ Todo mantenimiento debe estar autorizado, planificado, documentado y asociado a un responsable.
- ✓ Los mantenimientos en producción requieren ventana de mantenimiento, pruebas previas y plan de reversa.
- ✓ Debe preservarse la confidencialidad de los datos y limitar el acceso al personal autorizado.
- ✓ Los cambios se registran en bitácora o sistema de tickets.
- ✓ Debe verificarse la existencia de respaldos antes de cambios críticos.
- ✓ Las evidencias se conservan para auditoría y mejora continua.

Tipos de mantenimiento



Preventivo

Descripción

Acciones programadas para evitar fallas o incidentes.

Ejemplo ANSDP

Aplicación mensual de parches y revisión de logs.



Correctivo

Descripción

Acciones realizadas para corregir fallas detectadas.

Ejemplo ANSDP

Corrección de caída del portal o restauración de servicio.



Adaptativo

Descripción

Ajustes por cambios en plataforma, normativa o infraestructura.

Ejemplo ANSDP

Actualización por nueva regulación de datos personales.



Evolutivo

Descripción

Mejoras funcionales o de seguridad al sistema.

Ejemplo ANSDP

Implementación de MFA o mejora del monitoreo.

Procedimiento general de mantenimiento



Roles y responsabilidades

Rol	Responsabilidad principal
Dirección General	Aprobar recursos y respaldar la aplicación de la política.
Comité de Seguridad	Revisar cumplimiento, riesgos y acciones de mejora.
Jefe de TI	Planificar y autorizar mantenimientos tecnológicos.
Oficial de Seguridad	Verificar que los mantenimientos cumplan controles de seguridad.
Infraestructura TI	Aplicar parches, hardening, respaldos y mantenimiento de servidores.
DBA	Mantener bases de datos, respaldos, integridad y restauración de datos.
Desarrollo	Corregir vulnerabilidades y aplicar cambios en aplicaciones.
Soporte Técnico	Atender estaciones de trabajo, tickets y evidencias de usuario final.

Conclusiones



La ANSDP, al manejar información personal y expedientes digitales, requiere un SGSI que priorice la confidencialidad, integridad y disponibilidad de los datos ciudadanos.



La evaluación de riesgos identifica activos críticos: base de datos ciudadana, portal web, sistema de respaldos, servidor de autenticación y repositorio de expedientes.



Para el Grupo No. 5, los controles más relevantes se relacionan con seguridad en las operaciones, mantenimiento de sistemas, gestión de cambios, monitoreo, registros, respaldos y gestión de vulnerabilidades.



La política de mantenimiento y el checklist propuesto convierten los controles en actividades verificables, con responsables, frecuencia y evidencias.



El plan de contingencia complementa el SGSI al definir acciones de recuperación ante incidentes tecnológicos.

REFERENCIAS

Referencias bibliográficas

- Asamblea Nacional de Panamá, Unidad de Seguridad Informática. (2023). Manual de procedimientos administrativos: Unidad de Seguridad Informática.
- Asamblea Nacional de Panamá. (2019). Ley No. 81 de 26 de marzo de 2019, sobre protección de datos personales. Gaceta Oficial Digital No. 28743-A.
- International Organization for Standardization. (2018). ISO 31000:2018 Risk management — Guidelines.
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security management systems — Requirements.
- International Organization for Standardization. (2022). ISO/IEC 27002:2022 Information security controls.
- International Organization for Standardization. (2022). ISO/IEC 27005:2022 Guidance on managing information security risks.
- Ministerio de Gobierno de Panamá. (2021). Decreto Ejecutivo No. 285 de 28 de mayo de 2021, que reglamenta la Ley 81 de 2019.
- Swanson, M., Bowen, P., Phillips, A., Gallup, D., & Lynes, D. (2010). Contingency Planning Guide for Federal Information Systems (NIST SP 800-34 Rev. 1).
- Nelson, A., et al. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management (NIST SP 800-61 Rev. 3).